2026-1 NETWORK SECURITY

CLI 코딩 에이전트의 실행 흔적 추적 및 맥락 분석을 위한 디지털 포렌식 도구

20210789 박주환
20221903 박채민
20221343 변민정

인공지능공학부 컴퓨터공학전공

AgenTrace

목차

CONTENTS

I. 개발 배경

문제 제기 · 개발 배경 · 연구 공백

II. 도구 동작 구조

III. 활용 시나리오

III. 결론

기여 요약 · 한계 · 향후

AgenTrace

I.

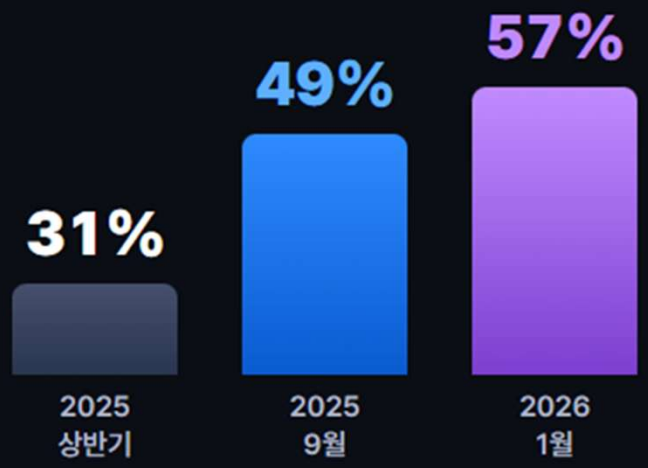
개발 배경

문제 제기 · 개발 배경 · 차별점

AgenTrace

개발 배경

AI 코딩 도구의 사용 환경이 터미널(CLI)로 빠르게 이동하고 있다



개발자의 Claude Code 인지도(awareness) · 개발자 1만명 대상

- 주요 기업(앤트로픽·구글·오픈AI)이 2025년 CLI 기반 코딩 도구를 잇따라 공개하며 **도입이 빠르게 확산**
- 대표 도구 **Claude Code**는 출시 **6개월만에 연환산 매출 10억 달러** 돌파(역대 최고속 성장), 사용자당 주 **20시간 이상** 사용

출처 https://blog.jetbrains.com/research/2026/04/which-ai-coding-tools-do-developers-actually-use-at-work/
https://www.anthropic.com/news/anthropic-raises-30-billion-series-g-funding-380-billion-post-money-valuation

AgenTrace

실제 사례

실제 유출이 발생했고, 예방만으로는 한계가 있다

유형 A · 사용자 직접 · 삼성, 2023년

직원이 ChatGPT에 직접 입력

20일 동안 **세 차례** — 반도체 코드·검사 프로그램·회의 내용을 직접 입력. 이후 사내 외부 AI 사용을 전면 금지



[단독] 우려가 현실로…삼성전자, 챗GPT 빗장 풀자마자 '오남용' 속출

정두용 기자

입력 2023.03.30 18:20 수정 2023.03.30 20:35

가 글자크기 | 공유 | 인쇄 | URL복사 | 댓글

반도체 사업장 챗GPT 허용 20일, 정보 유출 사고 3건 발생
설비 계측·수율 데이터, 미국 기업에 고스란히 전송…회수 불가
필요시 해당 임직원 징계…사내 전용 AI 서비스 구축 검토

유형 B · AI 자체 실행 · Nx 사건, 2025년

컨텍스트 수집 중 .env 시크릿까지 읽음

AI 코딩 에이전트가 코드 이해를 위해 프로젝트 파일을 훑다가 .env의 API 키, DB 암호를 그대로 읽어 LLM에 전송



Blog post • 6 min read

Your AI Coding Agent Is Reading Your .env File

Friday, April 10, 2026

PREVIOUS ARTICLE
OWASP Secrets Management Cheat Sheet: What You Need to Know

NEXT ARTICLE
Postmortem-Driven Development

∞ Infisical

- 두 사례 모두 데이터가 **외부 AI 경로**로 이동 – **A는 사용자**, **B는 에이전트**가 실행 주체
- 예방 도구를 사용해도 **정상 허용된 AI API 경로**는 차단 솔루션이 탐지하지 못함 -> 사고 발생

출처 ① https://economist.co.kr/article/view/ecn202303300057
② https://www.knostic.ai/blog/claude-cursor-env-file-secret-leakage / https://infisical.com/blog/your-ai-coding-agent-is-reading-your-env-file

AgenTrace

문제 제기

기록에 남은 행위의 주체 — 사용자, 에이전트?

분석 대상

CLI 코딩 에이전트가 디스크에 남긴 행위 기록

유형 A · 사용자

사용자 직접 행위

사용자가 직접 파일을 열거나
입력창에 붙여넣음

유형 B · 에이전트

에이전트 자율 행위

사용자 지시 없이 에이전트가
스스로 파일을 읽고 명령 실행

주체 미 구분 시 에이전트의 자율 행위가 사용자 행위로 잘못 귀속
- 행위 주체 식별이 본 도구의 핵심 전제

AgenTrace

조사 도구의 부재

사고가 발생해도 남은 기록을 분석할 도구가 없다

- **예방 도구에는 사각지대가 존재**
  - — 차단 위주로, 허용된 경로를 통한 유출은 탐지하지 못함
  - — 유출의 32%가 생성형 AI 경로(Zscaler 연 420만 건)
- **사고 후에는 수작업 분석에 의존**
  - — 방대한 기록을 일일이 검색
  - — 상용 포렌식 도구(EnCase, FTK, Cellebrite, AXIOM 등)도 CLI 코딩 에이전트 전용 파서 존재 X
- **선행 연구도 기록 폴더 내부는 미분석**
  - — 경로만 언급할 뿐, 내부 증거는 다루지 않음



출처 ① Zscaler ThreatLabz · LayerX — GenAI DLP 사각지대(2025) https://wald.ai/blog/ai-data-loss-prevention-ai-dlp-why-your-traditional-dlp-tool-cant-stop-genai-data-leaks
② Cyber Forensics Academy — Top Digital Forensic Tools 2025 https://www.cyberforensicacademy.com/blog/top-10-digital-forensic-tools-every-investigator-must-know
③ Kim & Jeong, SSRN 6725750 https://papers.ssrn.com/sol3/papers.cfm?abstract_id=6725750

선행 연구 대비 차별점

수작업 분석을 자동화 · 심층 분석 · 행위 주체 식별까지

기능	구현 도구	선행 연구 (Kim & Jeong, 2026)
파싱→분석→질의→대시보드 자동화	✓	수작업
붙여넣은 내용까지 추적해 원문 복원	✓	✗
기록 폴더 내부 증거 유형 분류	✓	미분석
행위 주체(사용자/AI) 식별	✓	✗
원본 무결성 확인(위·변조 검사)	✓	✗

비교 대상 선행 연구: Kim, Taewoo, and Doowon Jeong. "From assistant to accomplice: A forensic framework for CLI coding agents in incident response." Available at SSRN 6725750.

AgenTrace

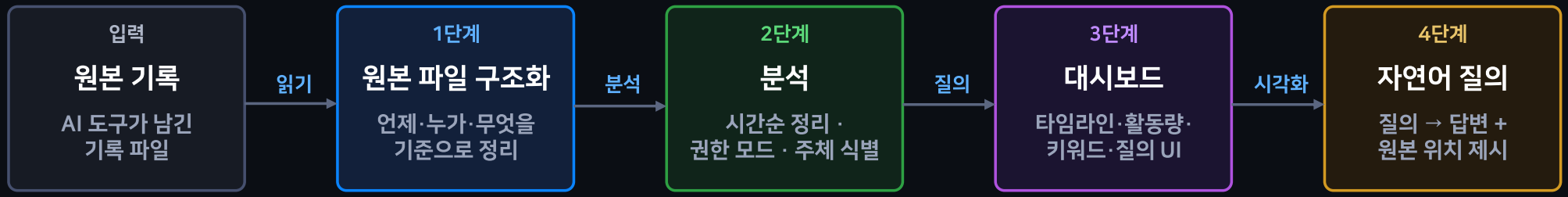
II.

도구 구조

AgenTrace

도구 구조

읽기 → 분석 → 질의 → 시각화, 모든 답변은 원본 위치로 추적 가능



규칙 기반 처리 결과가 **1차 증거** · AI는 **해석 보조** — 모든 답변은 **원본 파일·대화 내역**으로 추적 가능

AgenTrace

도구 구조

읽기 → 분석 → 질의 → 시각화, 모든 답변은 원본 위치로 추적 가능

입력
원본 기록
AI 도구가 남긴
기록 파일

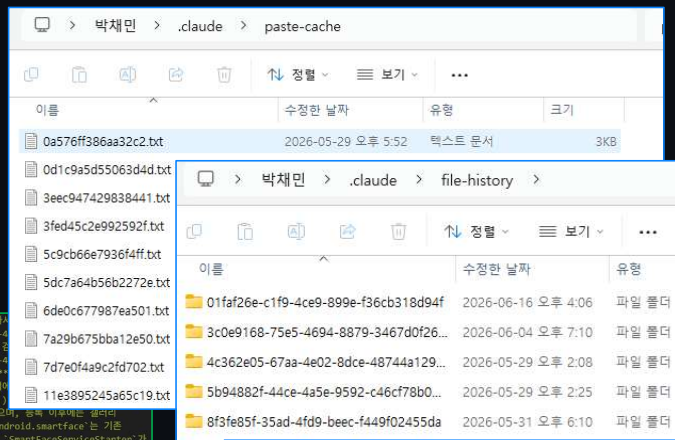
```
~/.claude/
├── projects/ 프로젝트별 세션 폴더
│   └── <session-uuid>.jsonl 대화·도구 사용 기록 · 접근 파일
├── history.jsonl 프롬프트 입력 이력
├── paste-cache/ 붙여넣은 원문(<hash>.txt)
├── file-history/ AI가 고친 파일의 수정 전 사본
└── shell-snapshots/ AI가 명령을 실행한 환경 기록
~/.claude.json MCP(외부 연동) 서버 설정 · 실사용과 대조
```

<session-uuid>.jsonl

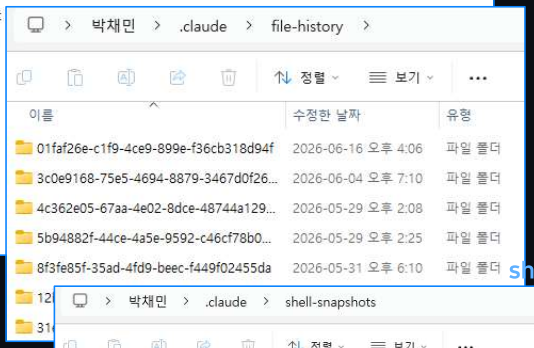


history.jsonl

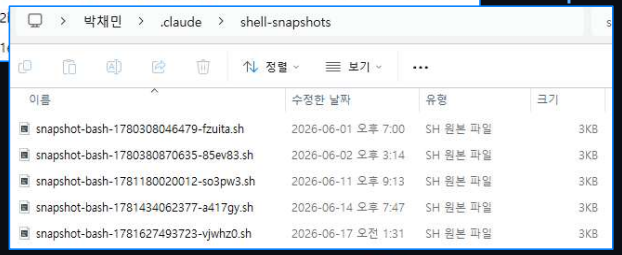
paste-cache/



file-history/



shell-snapshots/



AgenTrace

도구 구조

읽기 → 분석 → 질의 → 시각화, 모든 답변은 원본 위치로 추적 가능




```
{"display":"붙여넣은 고객 명단 csv에서 이메일 컬럼만 뽑아줘",
"pastedContents":{},
"timestamp":"2026-06-13T16:31:12Z",
"project":"gallery",
"sessionId":"gallery"}
```

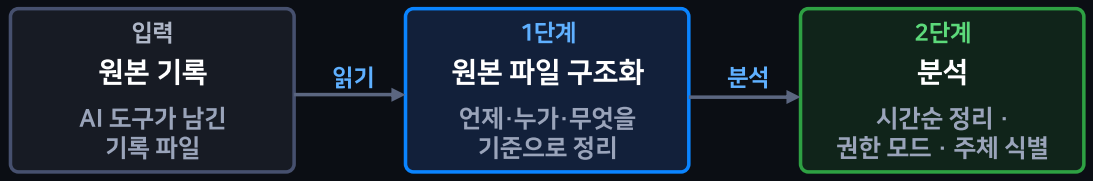
→

```
{"ts": "2026-06-13T16:31:12Z",  시간 정규화
"agent": "claude",     어느 도구
"session": "gallery",  세션
"actor": "user",  행위 주체
"action": "prompt",  행위 종류
"target": "",  대상(프롬프트는 빈칸)
"preview": "붙여넣은 고객 명단 csv에서 이메일 컬럼만 뽑아줘",  내용
"source": {"file": "clfx-out\\demo-claude\\projects\\-gallery\\sess.
jsonl", "line": 17},    원본 위치 추적
"tags": []}   분석 전이라 빈칸
```

AgenTrace

도구 구조

읽기 → 분석 → 질의 → 시각화, 모든 답변은 원본 위치로 추적 가능




```
{"ts": "2026-06-13T16:31:12Z",
"agent": "claude",
"session": "gallery",
"actor": "user",
"action": "prompt",
"target": "",
"preview": "붙여넣은 고객 명단 csv에서 이메일 컬럼만 뽑아줘",
"source": {"file": "clfx-out\\demo-claude\\projects\\-gallery\\sess.
jsonl", "line": 17},
"tags": []}
```

```
{"ts": "2026-06-13T16:31:12Z",
"agent": "claude",
"session": "gallery",
"actor": "user",
"action": "prompt",
"target": "",
"preview": "붙여넣은 고객 명단 csv에서 이메일 컬럼만 뽑아줘",
"source": {"file": "clfx-out\\demo-claude\\projects\\-gallery\\sess.jsonl", "line": 17},
"tags": []}
```

평범한 프롬프트라 빈칸 유지

```
{"ts": "2026-06-12T14:12:55Z",
"agent": "claude",
"session": "gallery",
"actor": "agent",
"action": "read",
"target": "/home/u/gallery/.env",
"preview":
"AWS_ACCESS_KEY_ID=AKIADEMOFAKE00000001\nAWS_SECRET_ACCESS_KEY=DEMOFAK
EsecretKeyAbcdefghij0123456789ABCD\n",
"source": {"file": "clfx-out\\demo-claude\\projects\\-gallery\\sess.
jsonl", "line": 9},
"tags": []}
```

```
{"ts": "2026-06-12T14:12:55Z",
"agent": "claude",
"session": "gallery",
"actor": "agent",
"action": "read",
"target": "/home/u/gallery/.env",
"preview": "AWS_ACCESS_KEY_ID=<secret>\nAWS_SECRET_ACCESS_KEY=<secret>\n",
"source": {"file": "clfx-out\\demo-claude\\projects\\-gallery\\sess.jsonl",
"line": 9},
"tags": ["secret", "bypass-mode"]}
```

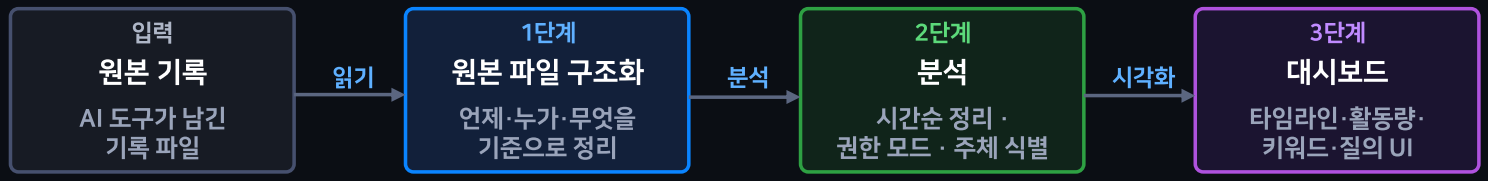
내용에서 실제 키를 <secret>로 치환해 저장

내용에 중요 키 발견(secret),
bypassPermissions 세션에서 일어남

AgenTrace

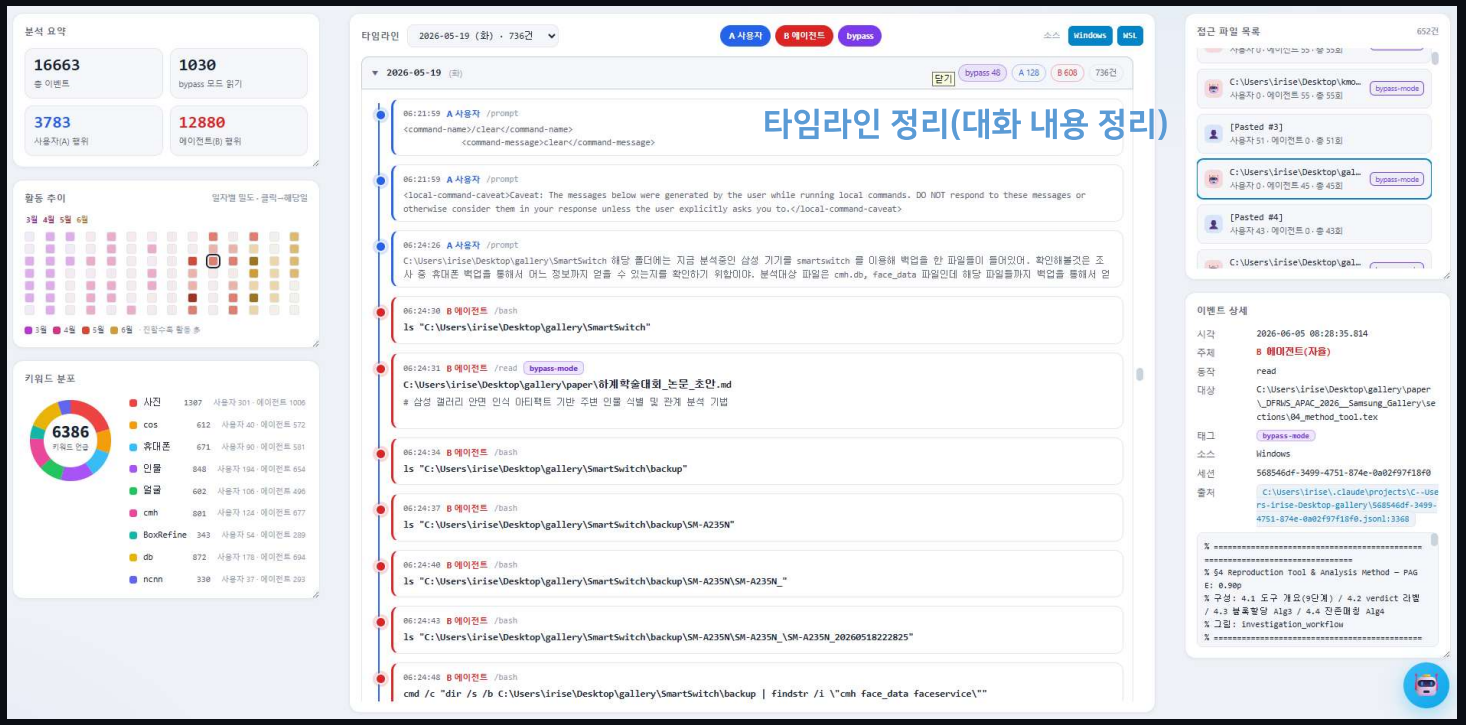
도구 구조

읽기 → 분석 → 질의 → 시각화, 모든 답변은 원본 위치로 추적 가능



날짜별 활동량

키워드 분석 결과



파일 접근 목록

이벤트 상세

AgenTrace

도구 구조

읽기 → 분석 → 질의 → 시각화, 모든 답변은 원본 위치로 추적 가능

입력
원본 기록
AI 도구가 남긴 기록 파일

→ 읽기

1단계
원본 파일 구조화
언제·누가·무엇을 기준으로 정리

→ 분석

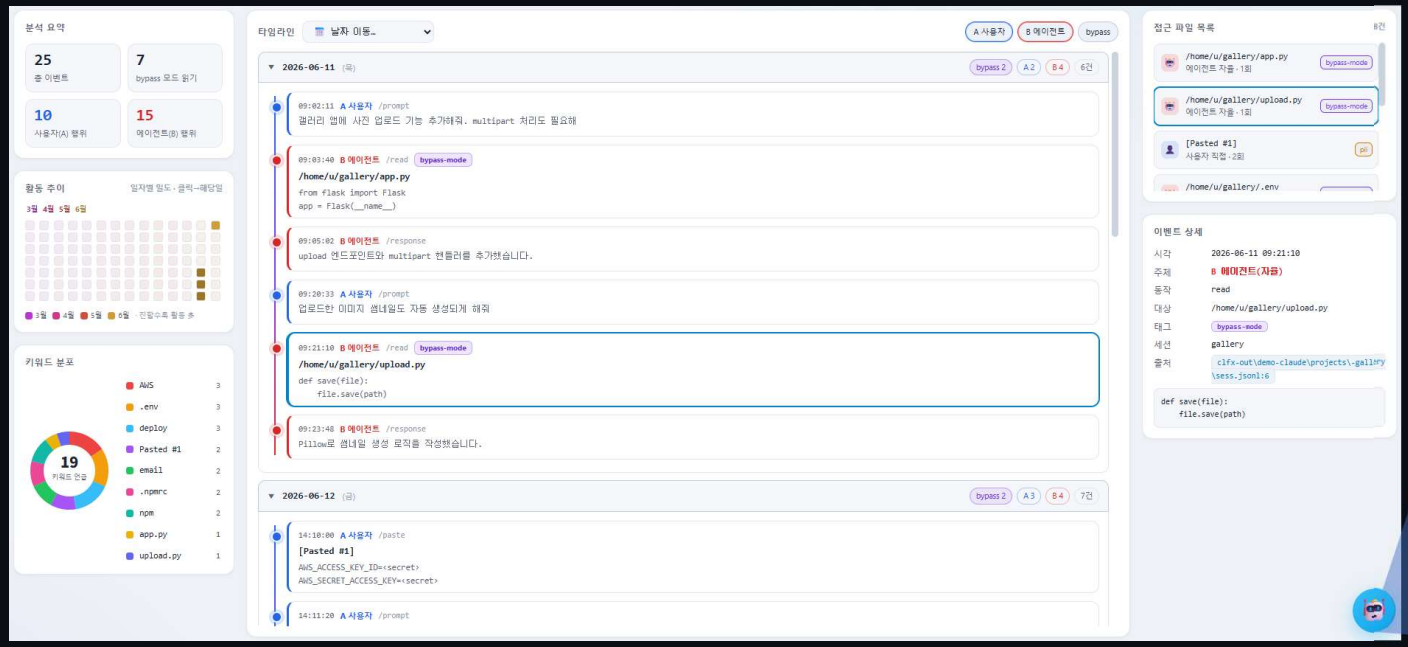
2단계
분석
시간순 정리 · 권한 모드 · 주체 식별

→ 시각화

3단계
대시보드
타임라인·활동량·키워드·질의 UI

→ 질의

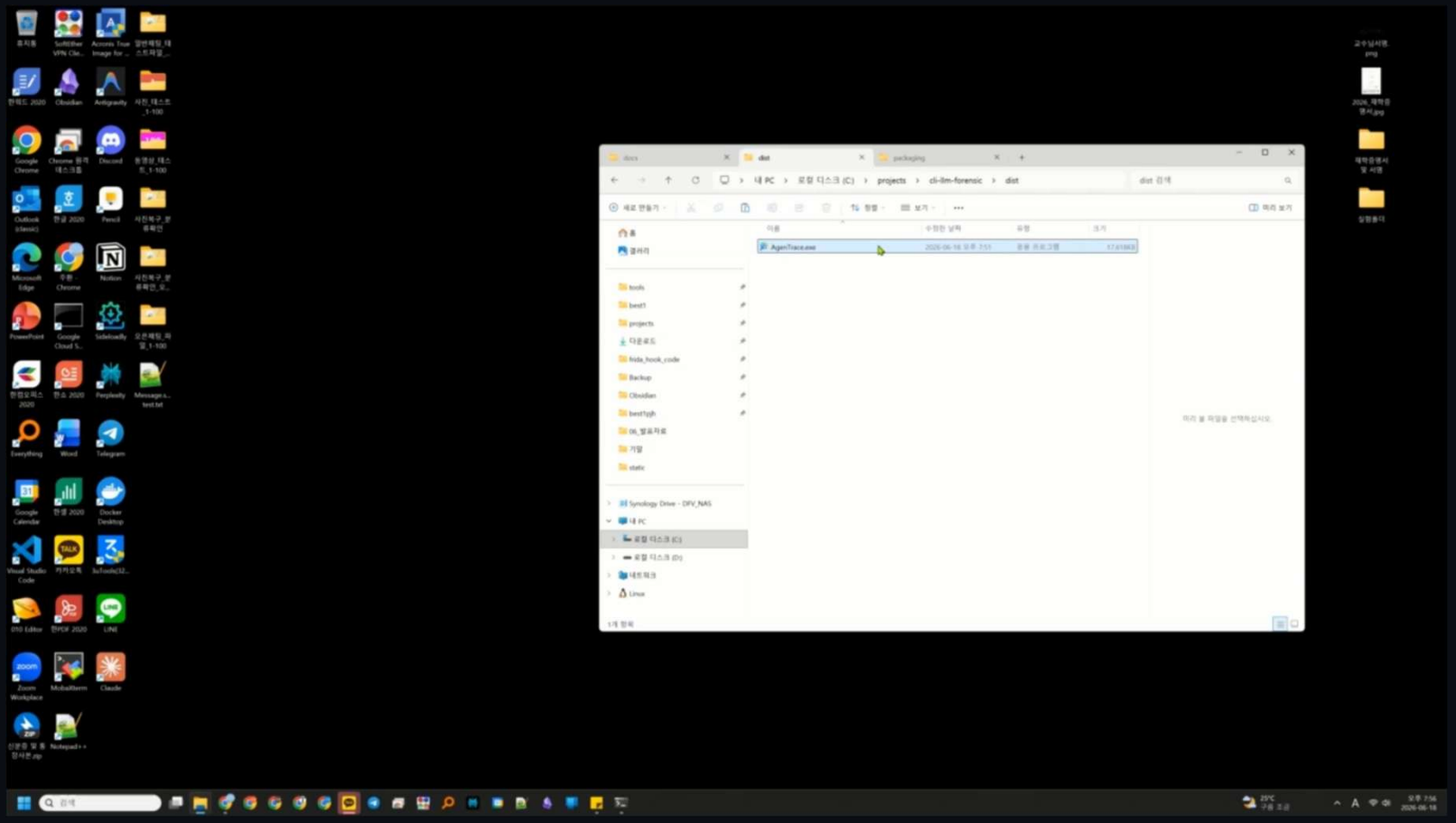
4단계
자연어 질의
질의 → 답변 + 원본 위치 제시





도구 동작 영상

요청된 시각화를 동작 대시보드로 — 모든 답은 대화 내역으로 추적



AgenTrace

III.

활용 시나리오

AgenTrace

활용 시나리오 ① 사건 발생

만약 기밀이 외부 AI로 샜다면 — 수사는 무엇부터

사건 개요

적발 계기

외부 AI 전송 정황 포착 → PC 압수

DLP(Data Loss Prevention, 데이터 유출 방지 보안 솔루션)가 외부 AI 도메인 업로드를 경보(또는 보안 점검 · 내부 고발)

외부 서버 내부는 볼 수 없어, 압수한 직원 PC의 ~/.claude 기록이 핵심 증거.

수사관의 3가지 의문

- 무엇이 나갔나 — 어떤 파일·내용
- 언제·어떤 경로로 — 시점과 전송 흔적
- 누가 — 사용자(A)인가, AI 에이전트(B)인가

방대한 기록을 수작업으로 검색하기엔 한계 존재

AgenTrace

활용 시나리오 ② 도구로 수사

압수 기록을 스캔 → 질의 → 주체 판별, 수사관이 직접

① 스캔

읽기 전용 파싱 + 원본 SHA-256 기록

- 원본 미변경 · 무결성 확보

② 타임라인·히트맵·주체 판별

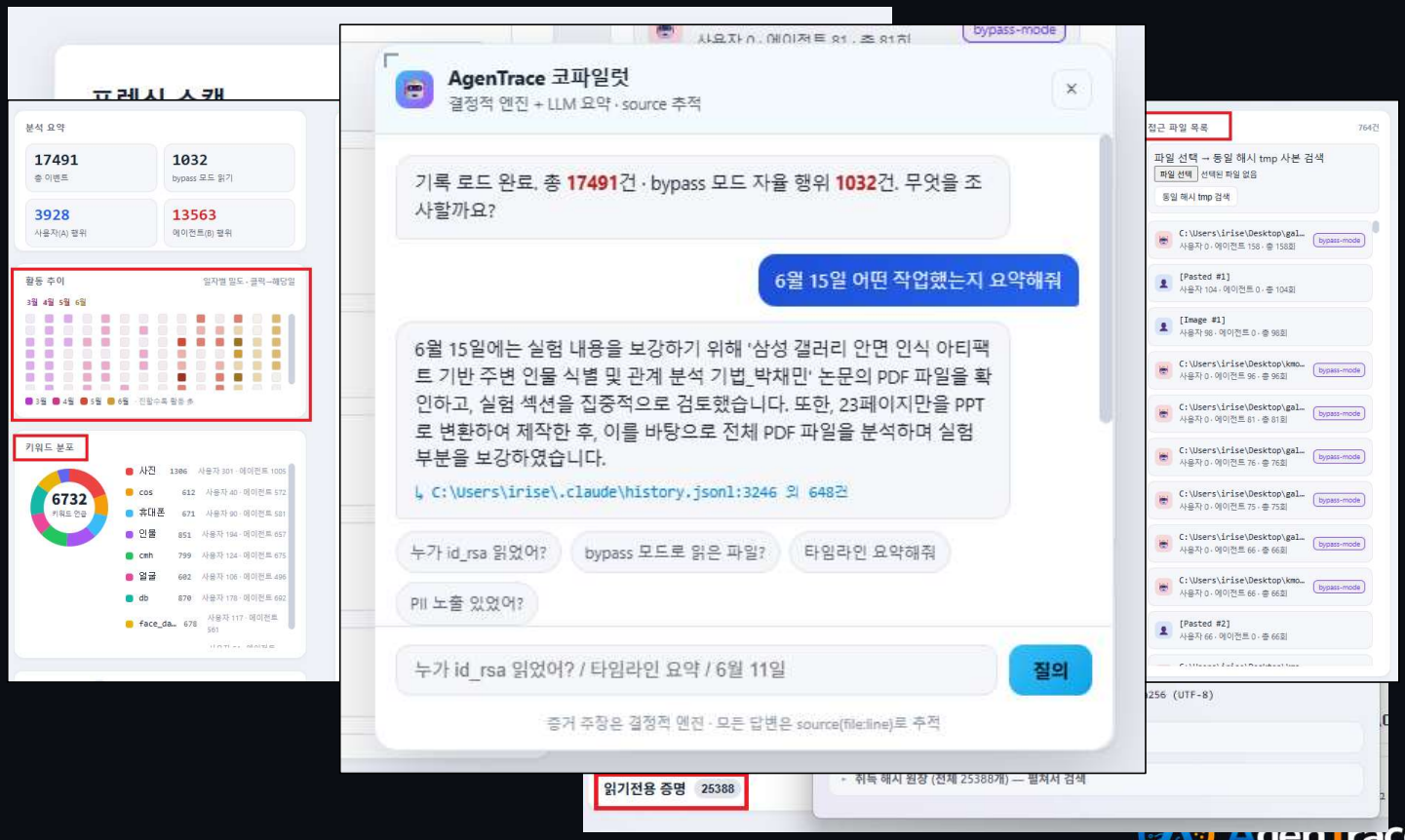
사건 시각 전후 행위 압축 /
행위 주체 확인 · bypass 모드 여부

- 활동 이상 급증 구간 포착
- 사용자 vs 에이전트

③ 자연어 질의

"6월 12일 요약" "OO 파일 접근 기록 보여줘 "

- 답변 + 원본 위치 제시



활용 시나리오 ③ 수사 결론

10 ★

source 역추적으로 사실을 확정

A로 판명 · 사용자 직접

본인이 직접 붙여넣음

- 민감 파일을 사용자(A)가 직접 열어 **프롬프트·붙여넣기**로 외부에 전송
- 행위 주체가 **사람**으로 특정되고, 시각·대상·원본 위치 동반 기록

B로 판명 · 에이전트 자율

AI가 bypass로 자율 반출

- 사용자의 직접 지시는 없으나, 에이전트(B)가 **bypass** (권한 확인 생략) 모드에서 민감 폴더의 파일을 자율로 읽어 전송
- 해당 모드를 **어떤 폴더 및 세션에서 사용했는지**에 대한 기록 잔존

두 결론 모두 **원본 위치 역추적 + 원본 해시 보존**으로 재현 가능
도구는 주체·시각·경로 등 **행위 사실 제시** — 조사·판단을 돕는 **분석 자료** 역할 수행

AgenTrace

검증 및 포렌식 건전성

원본 무결성·재현성 ·검증

1 · 무결성

원본 미변경·읽기 전용 분석

기록을 **읽기 전용**으로만 처리해 원본 보존
➔ **SHA-256** 해시로 파일 동일성을 식별

2 · 재현성

같은 질문 -> 항상 같은 답

누가 · 언제 사용해도 **답과 출처가 동일**
➔ 정해진 규칙대로 계산(추측 X)해 **재현 가능**

3 · 검증

도구 정확도 확인

통제 데이터셋을 통해 주체 식별, 접근 파일 판정 정확도 산출
➔ 100%

AgenTrace

IV.

결론

AgenTrace

결론

예방 도구의 사각지대를 보완하는 디지털포렌식 도구

기여

- **전용 분석 · 시각화 및 도구화**
  — CLI 코딩 에이전트가 생성하는 아티팩트를 정리·분석·시각화하는 최초의 포렌식 도구
- **분석 범위 확장**
  — 붙여넣은 내용 · 폴더 내부 분석 및 시각화
  — MCP 연결 흔적 · tmp 폴더 내부 분석 및 시각화
- **행위 주체 식별** — 사용자(A)·AI(B) 구분
- **자연어 질의 분석**
  — 자연어 질의로 기록을 분석 및 요약
- **무결성**
  — SHA-256 해시 대조로 무결성 확보

한계 및 향후 과제

- **범용화** — Codex·Gemini CLI 확장
- **버전 변경 시 형식 상이**

AgenTrace

감사합니다

CLI 코딩 에이전트의 실행 흔적 추적 및
맥락 분석을 위한 디지털 포렌식 도구

Q & A

AgenTrace

APPENDIX

정확도 검증 — 실 에이전트 통제 데이터셋

EVAL · N=300

데이터를 **위조하지 않고** 실제 CLI 에이전트를 구동해 생성 · 정답 = **내가 명령한 행위(런북)**

데이터셋 구성

① **베이스라인 동결** — 작업 전 `~/.claude` 매니페스트로 신규 세션만 격리

② **실 에이전트 구동** — `claude -p` 헤드리스로 런북 실행(실제 read·write·MCP·프롬프트)

③ **신규 세션 격리** — `session_id`로 그 세션 jsonl만 추출

④ **런북 정답과 1:1 채점** — 도구 출력 Event ↔ 명령한 행위 대조

주체	user 50	agent 50	100
접근파일	read 50	write 50	100
MCP	mcp 호출 100 (fsmcp / read_text_file)		100

데이터 = **실 에이전트가 생성한 진짜 jsonl**(위조 아님) · 정답 = **런북**(파서 역산 아님)
접근 101턴 · MCP 102턴 · 주체 50프롬프트 체인 — 모두 `--output-format json`의 session_id로 격리

정확도 결과



주체 식별
혼동행렬 **50-50** 대각
오분류 **0**

접근 파일
recall **100%**
action 오분류 **0**

MCP 호출
server·tool **100%**
내장Read 오인 **0**

300 / 300 통제 데이터 전 축 **정확도 100%** — 누락 0 · 오분류 0
+ bypass 권한모드 탐지 · 외부 Notion MCP(N=1) 별도 검증

해석 통제 데이터셋 기준 무손실·무오분류(파서 매핑 정확). 현실 데이터 일반화·노이즈 견딤과는 구분 · 실데이터 약 1.6만 이벤트에서도 독립 추출 대비 전 축 일치.

AgenTrace